Gluu-CIMD--Solo.io

Mohibuzzaman Zico

MCP Security Interoperability Test (SIT) Dec 2026

CIMD Interoperability Testing Log

File name: `Gluu-CIMD--Solo.io`
Tester: Gluu (Mohibuzzaman Zico, zico@gluu.org). All times UTC. Both Gluu servers ran with DEBUG logging for the test.

When Performed

Started: 2026-10-13 16:06:15 UTC
Ended: 2026-10-13 16:06:29 UTC
Where performed: online

Participants

Role	Company and Product	Representative	Email
MCP Client	Solo.io: Solo Enterprise for agentgateway (OAuth issuer, upstream OAuth client)	Nick Gamb	nick.gamb@solo.io
OAuth AS	Gluu: Gluu Flex / Janssen (ledger-demo.gluu.info)	Mohibuzzaman Zico	zico@gluu.org

Test Report

The OAuth AS section is removed (Gluu's own role).

MCP Client Operation

Section	Title	MCP Client (Solo.io)
Client ID Metadata	redirect_uris support	✅ (log 1)
Client ID Metadata	jwks_uri support	✅ (logs 1 and 3: Gluu fetched the client's JWKS)
Client ID Metadata	jwks support	
Code grant with PKCE	None (public client)	
Code grant with PKCE	JWT	✅ (private_key_jwt, PS256: logs 2 and 4)
Code grant with PKCE	MTLS	
Client creds grant	JWT	
Client creds grant	MTLS	

Test Logs, Screenshots and Videos

Log 1. ledger-demo downloads the client ID metadata document (the client_id is its URL), 16:06:16

```
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "HTTP/1.1 200 OK[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "content-type: application/json[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "cache-control: no-store[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "content-length: 570[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "date: Tue, 13 Oct 2026 16:06:16 GMT[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "server: envoy[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:73) - http-outgoing-0
<< "[\r][\n]"
2026-10-13 16:06:16,522 DEBUG [qtp1176735295-16]  [org.apache.http.impl.conn.Wire] (Wire.java:87) - http-outgoing-0
<< "{"client_id":"https://mcp.sterling.18-225-65-61.sslip.io/c/gl2.json","client_name":"Sterling & Vance
(agentgateway)","redirect_uris":["https://mcp.sterling.lab/oauth-issuer/callback/upstream"],"grant_types":
["authorization_code"],"response_types":
["code"],"token_endpoint_auth_method":"private_key_jwt","token_endpoint_auth_signing_alg":"PS256","scope":"openid
email","default_acr_values":["simple_password_auth"],"jwks_uri":"https://mcp.sterling.18-225-65-61.sslip.io/clients/
agentgateway-gluu-2/jwks.json","access_token_as_jwt":true,"access_token_signing_alg":"RS256"}"
```

Log 2. ledger-demo, authorization request with code_challenge_method S256, 16:06:16

```
2026-10-13 16:06:16,767 DEBUG [qtp1176735295-16] 80c5fe4e-528b-4229-8dce-0b9e4e76994a
[as.server.authorize.ws.rs.AuthorizeRestWebServiceImpl] (AuthorizeRestWebServiceImpl.java:289) - Attempting to
request authorization: AuthzRequest{scope='openid email', responseType='code', clientId='https://
mcp.sterling.18-225-65-61.sslip.io/c/gl2.json', redirectUri='https://mcp.sterling.lab/oauth-issuer/callback/
upstream', state='<redacted>', responseMode='null', nonce='null', display='null', prompt='null', maxAge=null,
uiLocales='null', idTokenHint='null', loginHint='null', acrValues='null', amrValues='null', request='null',
requestUri='null', sessionId='null', originHeaders='null', codeChallenge='<redacted>', codeChallengeMethod='S256',
customResponseHeaders='null', claims='null', authReqId='null', dpopJkt='null', dpop='null', authzD...
```

Log 3. ledger-demo fetches the client's JWKS from its jwks_uri while validating the client assertion, 16:06:26

```
2026-10-13 16:06:26,779 DEBUG [qtp1176735295-22]  [io.jans.as.model.util.JwtUtil] (JwtUtil.java:248) - Retrieving
jwks https://mcp.sterling.18-225-65-61.sslip.io/clients/agentgateway-gluu-2/jwks.json...
```

Log 4. ledger-demo, token request: authorization_code with private_key_jwt (client_assertion) and PKCE code_verifier, 16:06:29

```
2026-10-13 16:06:29,389 DEBUG [qtp1176735295-22] b911cbbe-cd18-4a66-a681-75a50d0f5c14
[as.server.token.ws.rs.TokenRestWebServiceImpl] (TokenRestWebServiceImpl.java:170) - Attempting to request access
token: grantType = authoriza...
```

Notes and disclosures

- sterling-idp.gluu.info runs Janssen 2.5.0. ledger-demo.gluu.info runs Janssen 2.4.1 (Flex).
- Token values (client_assertion, assertion, subject_token, code, code_verifier, state, code_challenge) are replaced by `<redacted>`. Everything else is raw jans-auth.log output.
- The client requested `openid email`. ledger-demo granted only `openid` (log: "Granted scopes: [openid]"). This is a Gluu limitation that does not block the flow.
- ledger-demo re-downloads the client metadata document on every request ("Persisted CIMD client ... has expired, re-downloading"). It works but is not cached.
- ledger-demo does not yet advertise `code_challenge_methods_supported` in its metadata (added in Janssen 2.5.0), although PKCE S256 is accepted.